



Security Architecture Principles

Agenda

- 1 Overview of security architecture
- 2 The OSI model
- 3 Defense in depth
- 4 Information flow control
- 5 Isolation and segmentation
- 6 Loggin, monitoring and detection
- 7 Encryption fundamentals, techniques and applications

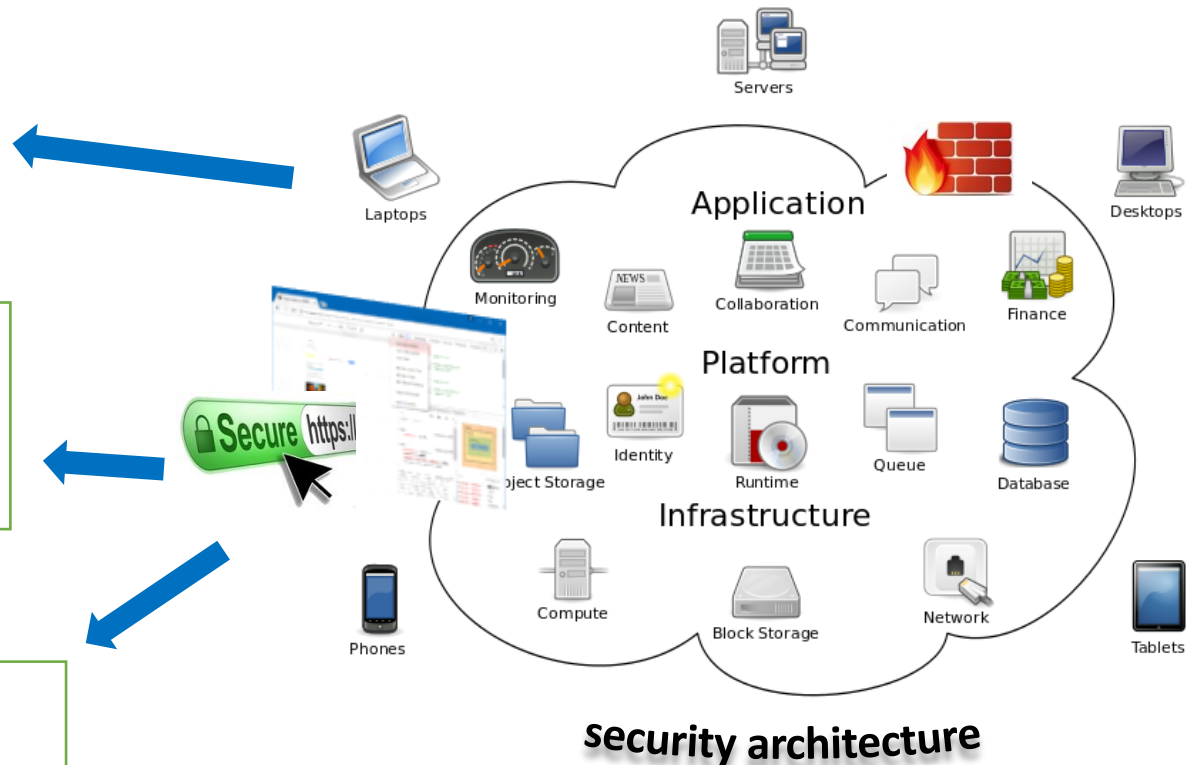
Overview of security architecture

- Describe structure, components, connections and security controls in the TI infrastructure of an organization.

Each component of a systems poses its own security risk

The architecture shows how the defense-in-depth is being implemented and how the layers are linked

There are different types of security architectures



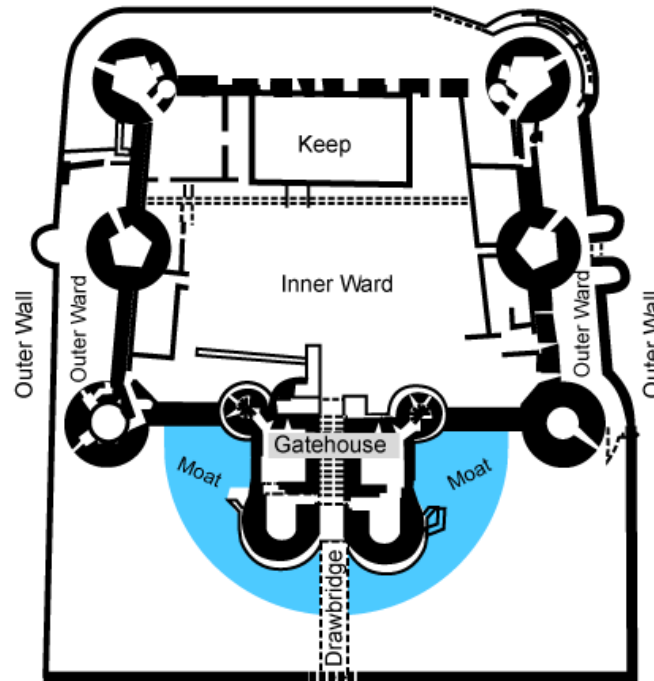
Overview of security architecture

The Security Perimeter

Tradicionalmente se ha definido un perímetro de seguridad teniendo como foco **la red** o el **sistema**.

Con el advenimiento del Internet, los dispositivos móviles, la nube y el IoT, el perímetro se ha expandido considerablemente.

Y ahora existen nuevos riesgos y vulnerabilidades en un nuevo entorno **hiperconectado** y **extendido**.



Un **perímetro de Internet** debe:

1. Enrutar el tráfico entre la empresa e Internet.
2. Impedir que los archivos ejecutables se transfieran a través de archivos adjuntos de correo electrónico o respuestas HTTP.
3. Monitorear los puertos de red para actividad deshonesta.
4. Detectar y bloquear el tráfico de puntos finales internos infectados.
5. Controlar el tráfico de usuarios vinculado a Internet.
6. Identificar y bloquear el tráfico anómalo y los paquetes maliciosos reconocidos como posibles ataques.
7. Elimina amenazas tales como spam de correo electrónico, virus y gusanos.
8. Aplicar políticas de filtrado para bloquear el acceso a sitios web que contengan malware o contenido dudoso.

Ahora el perímetro de seguridad debe estar centrado en los **datos**, protegiéndolos independientemente de su ubicación.

El perímetro debe proporcionar protección para redes privadas virtuales (VPN), redes de área amplia (**WAN**) y redes de área local inalámbricas (**WLAN**).

Overview of security architecture

Interdependencies

Las arquitecturas de TI modernas generalmente se descentralizan y se salen del perímetro. Existe una tendencia hacia el uso de dispositivos móviles inteligentes como tabletas o teléfonos inteligentes personales tipo **BYOD**

How to mitigate this?



La forma más directa de mitigar estos riesgos es mediante soluciones de tipo **DLP (Data Loss Prevention)** –We will see this in Section 3



En arquitecturas de TI distribuidas y descentralizadas, es probable que **aumente el riesgo de terceros** debido al traslado de aplicaciones críticas, plataformas y elementos de infraestructura (storage, middleware) a la nube.



How to mitigate this?

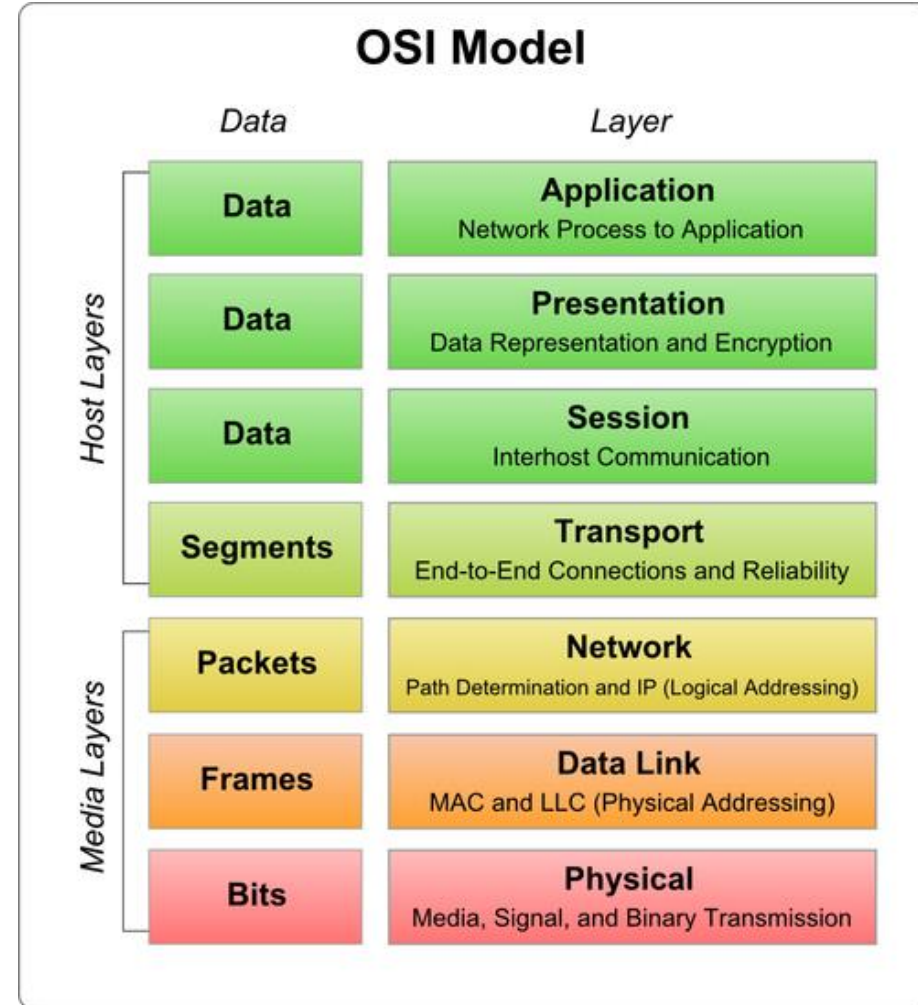
La forma más directa de mitigar estos riesgos en terceros es mediante contratos y **SLA (Service Level Agreement)**

Y a menudo hay áreas expuestas dentro de las arquitecturas de TI: **sistemas heredados, partes de la arquitectura sin parches**, dispositivos móviles de "dual persona" y muchos otros.

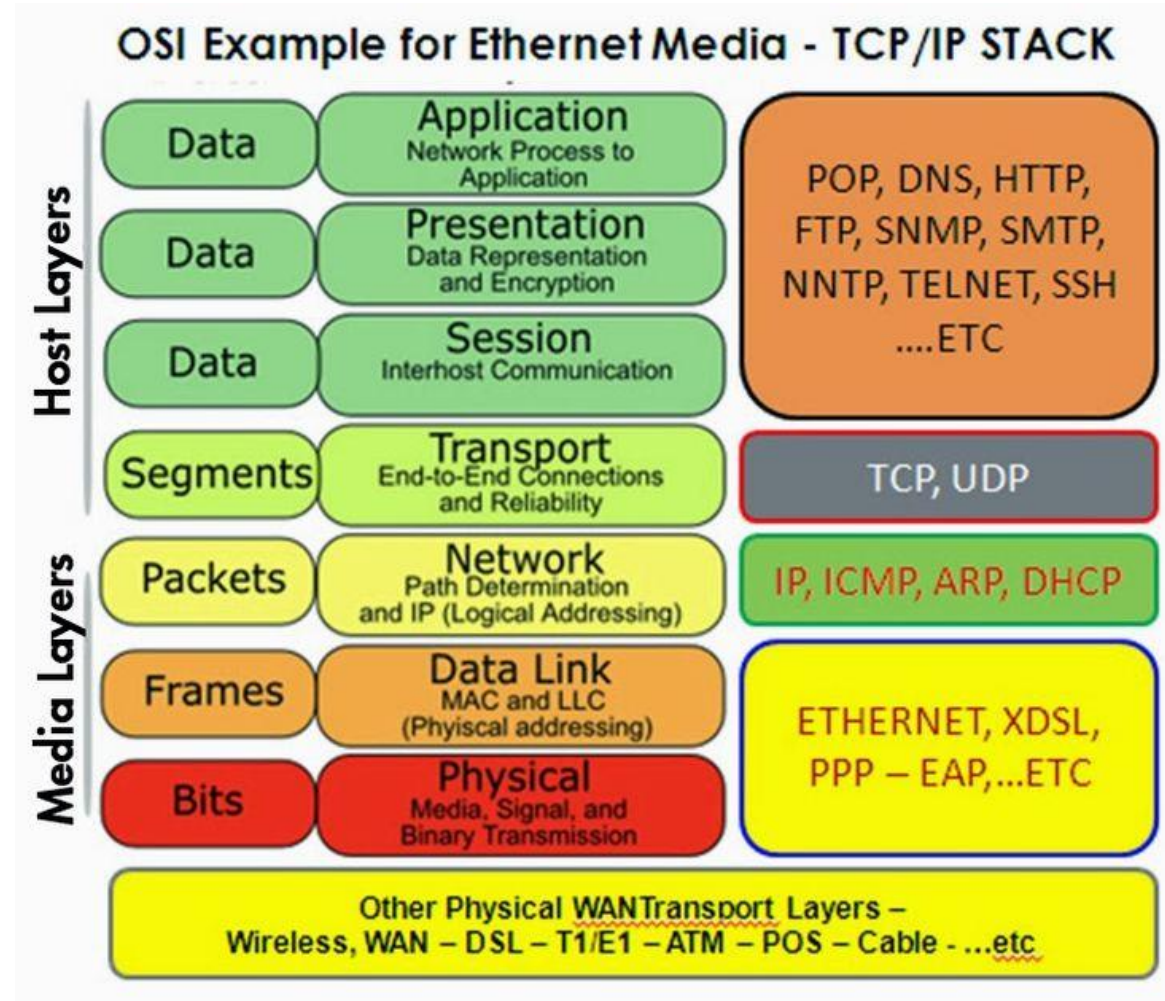
The OSI Model

El modelo OSI se usa para describir protocolos de comunicaciones. Es un modelo **referencial** para estandarizar el desarrollo de redes y fue la primera definición abierta no patentada para redes.

El **modelo OSI** define grupos de funcionalidades requeridas para las computadoras en capas, y cada capa implementa un conjunto de protocolos para su funcionalidad.

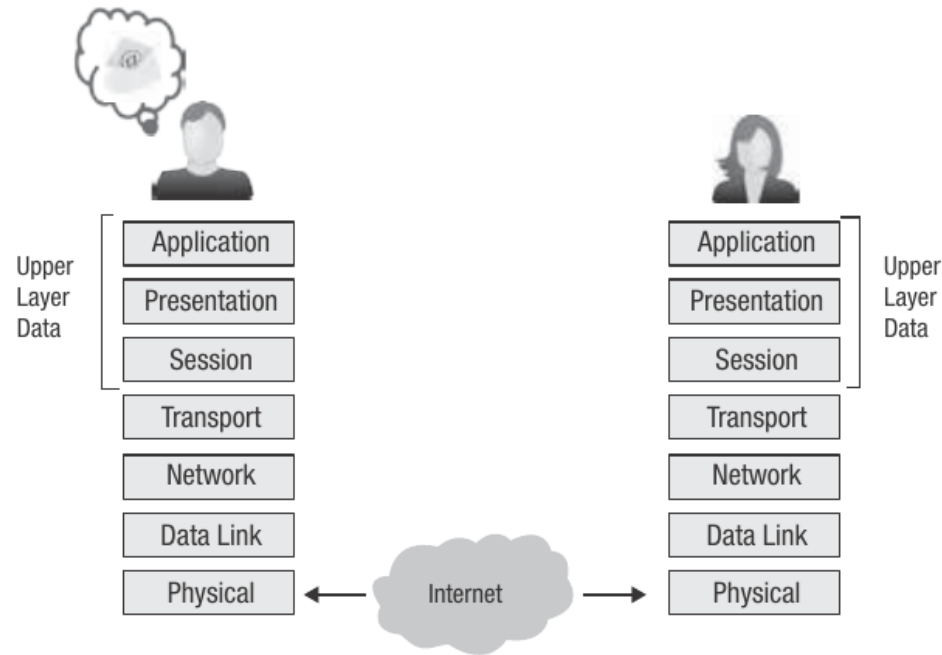


COMPARISON BETWEEN TCP/IP AND OSI MODEL



The OSI Model

Encapsulation in the OSI MODEL



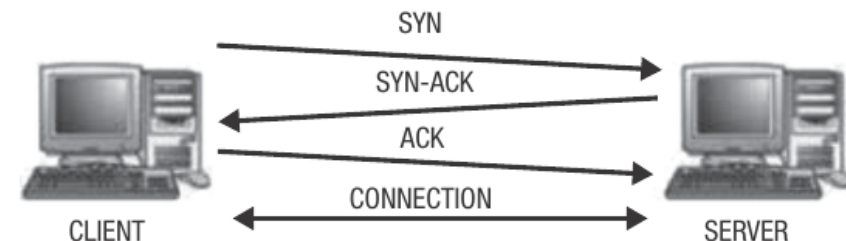
En la capa 4 existen protocolos orientados **a conexión o sin conexión**:

- i) Orientado a conexión: TCP proporciona una entrega confiable y secuenciada con comprobación de errores. Las conexiones se establecen usando un handshake de tres vías.
- ii) No orientado a conexión: El protocolo de datagrama de usuario (UDP) es un protocolo sin conexión utilizado donde la velocidad es más importante que la comprobación de errores y la entrega garantizada. UDP usa sumas de comprobación para integridad de datos.

Encapsulation is the process of adding addressing data to the data when those are transmitted through the OSI model

Each layer of the OSI Model only communicates with its the layer in the other peer. This is made using any PDU:

Decapsulación: Una vez en el destino, cada capa en el extremo receptor elimina la información de direccionamiento apropiada y la pasa por la pila OSI hasta que se entregue el mensaje.



Agenda

- 1 Overview of security architecture
- 2 The OSI model
- 3 Defense in depth
- 4 Information flow control
- 5 Isolation and segmentation
- 6 Loggin, monitoring and detection
- 7 Encryption fundamentals, techniques and applications

Defense in Depth

Non security control or countermeasure CAN eliminate the risk, so it is important to use many controls to protect an asset



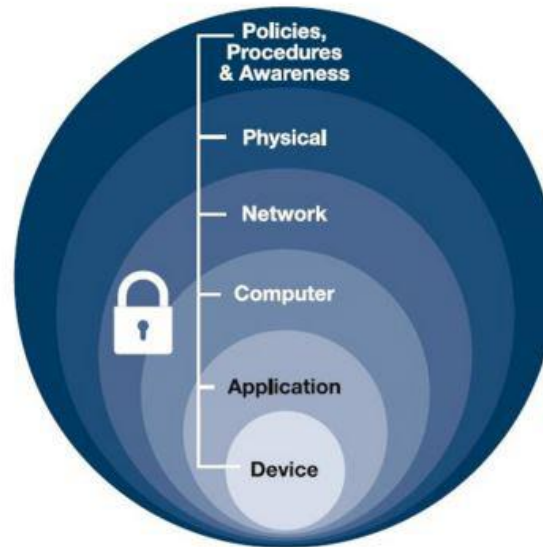
It is probable that an excessive confidence in a single control make a fake trust sensation.



Making protection by layers is known as Defense in Depth



Defense-in-Depth forces an adversary to pass by more than one security control to get access to an asset.



The number and kind of layers that are needed to protect an asset depends on the asset value, the criticality, the control reliability and the exposure level.



Using a Defense-in-Depth strategy to implement controls brings advantages like:

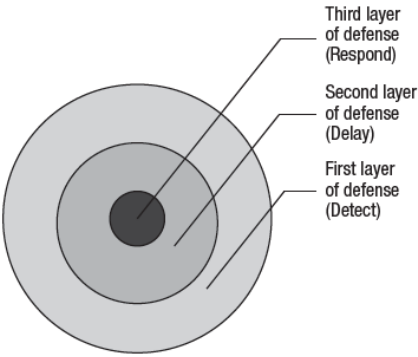
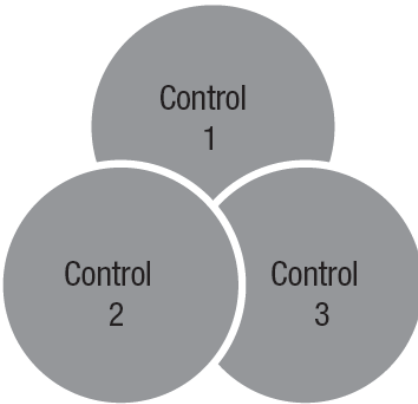
- i) increase the effort that an attacker has to do
- ii) create additional opportunities to detect an attack
- iii) delay an attack so it can be interrupted and avoided



Another defense strategy can be the education and awareness to create a “human firewall” that behaves as a defense critical layer

Defense in Depth

The Defense-in-Depth is an important design concept in the development of a security strategy.
Different ways to implement Defense -in-Depth:

Type of Defense	Graphical Representation	Description
Concentric Rings (or nested layering)	 The diagram shows three concentric circles. The innermost circle is labeled 'First layer of defense (Detect)'. The middle ring is labeled 'Second layer of defense (Delay)'. The outermost ring is labeled 'Third layer of defense (Respond)'.	Creates a series of nested layers that must be bypassed in order to complete an attack. Each layer delays the attacker and provides opportunities to detect the attack.
Overlapping redundancy	 The diagram shows three overlapping circles labeled 'Control 1', 'Control 2', and 'Control 3'. The circles overlap in a way that creates multiple overlapping regions, illustrating redundancy.	Two or more controls that work in parallel to protect an asset. Provides multiple, overlapping points of detection. This is most effective when each control is different.

Defense in Depth

Type of Defense	Graphical Representation	Description
Segregation or compartmentalization		Compartmentalizes access to an asset, requiring two or more processes, controls or individuals to access or use the asset. This is effective in protecting very high value assets or in environments where trust is an issue.

Source: CSX Cybersecurity Fundamentals, Study Guide, 2nd Edition

Another way to think about Defense-in-Depth:

- **Horizontal defense in depth:** Controls are placed in various places in the path of access for an asset.
It is equivalent to concentric ring model
- **Vertical defense in depth:** Controls are placed at different system layers (hardware, operating system, application, database or user levels)

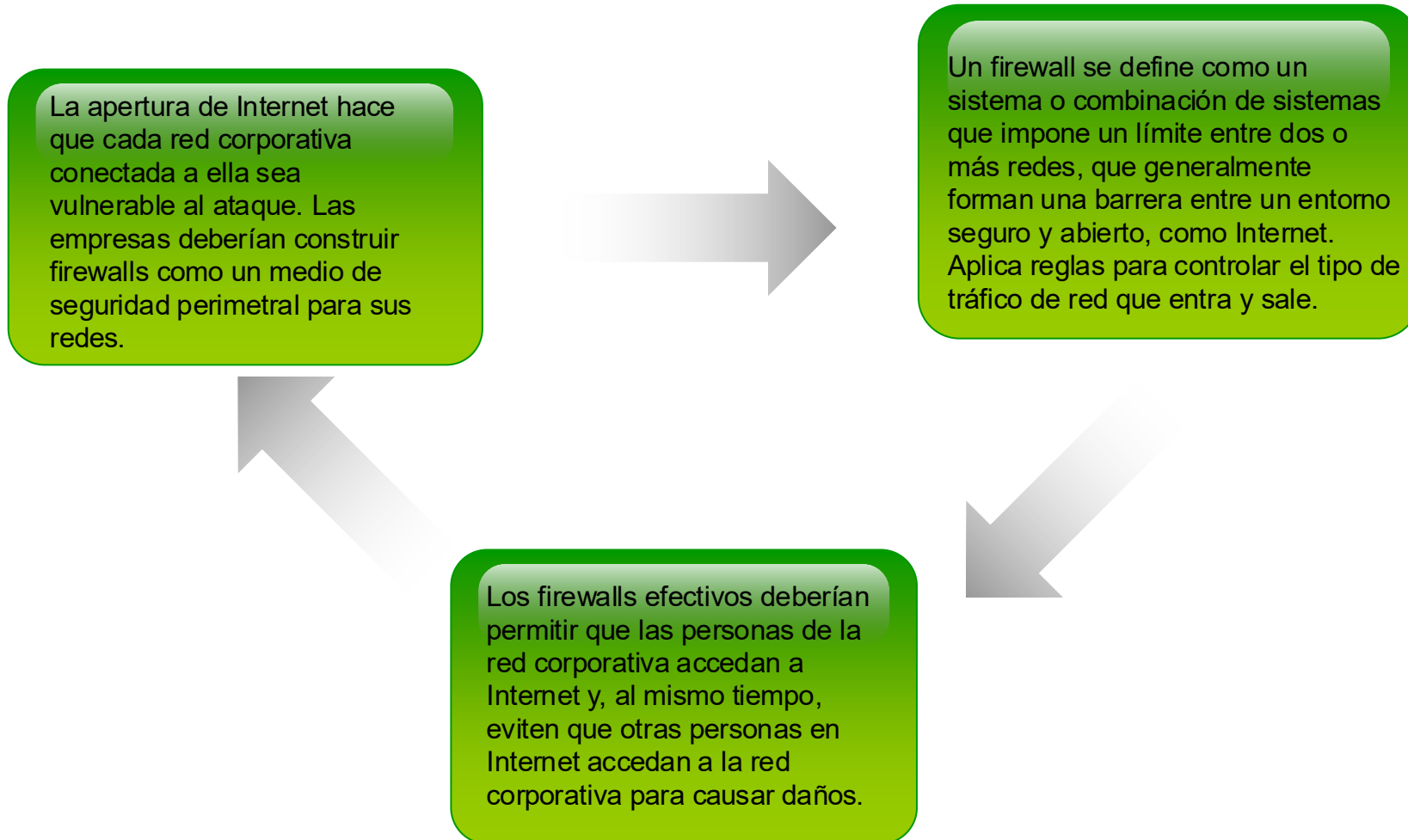
Before deciding which layer to implement think about:

1. What vulnerabilities are addressed by each layer or control?
2. How does the layer mitigate the vulnerability?
3. How does each control interact with or depend on the other controls?

Agenda

- 1 Overview of security architecture
- 2 The OSI model
- 3 Defense in depth
- 4 Information flow control
- 5 Isolation and segmentation
- 6 Loggin, monitoring and detection
- 7 Encryption fundamentals, techniques and applications

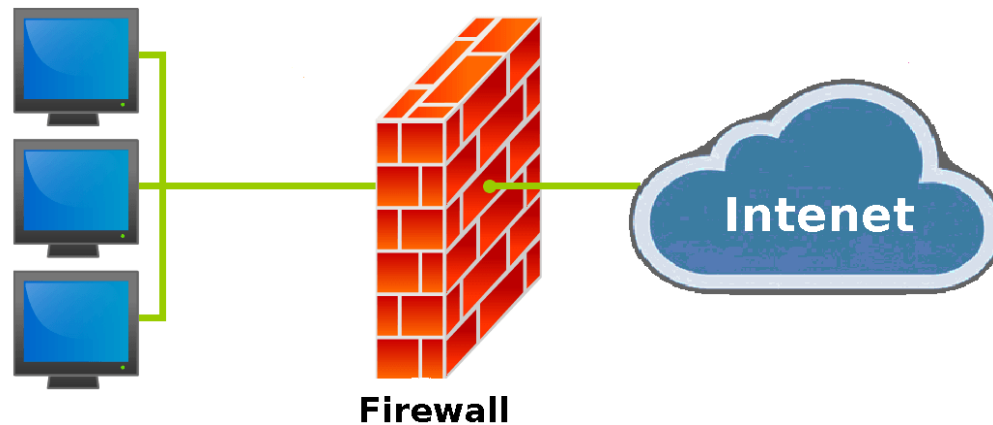
Information Flow Control



Information Flow Control

Firewall General Features

Junto con otros tipos de seguridad (**IDS / IPS**), los firewalls controlan el punto más vulnerable entre una red corporativa e Internet, y pueden ser tan simples o complejos como lo exige la política de seguridad de la información corporativa.



Permiten:

- Bloquear el acceso a sitios particulares en Internet.
- Limitar el tráfico en el segmento de servicios públicos de una organización a direcciones y puertos relevantes.
- Impedir que ciertos usuarios accedan a ciertos servidores o servicios.
- Monitorear y registrar las comunicaciones entre una red interna y una externa.
- Monitorear y registrar las comunicaciones entre una red interna y el mundo exterior para investigar penetraciones o detectar subversión interna.
- Encriptar paquetes que se envían entre diferentes ubicaciones dentro de una organización mediante la creación de una VPN.

Information Flow Control

Network Firewall Types

Types of firewalls:

1. Packet filtering
2. Stateful inspection
3. Application Firewall
4. New Generation Firewall (NGFW)

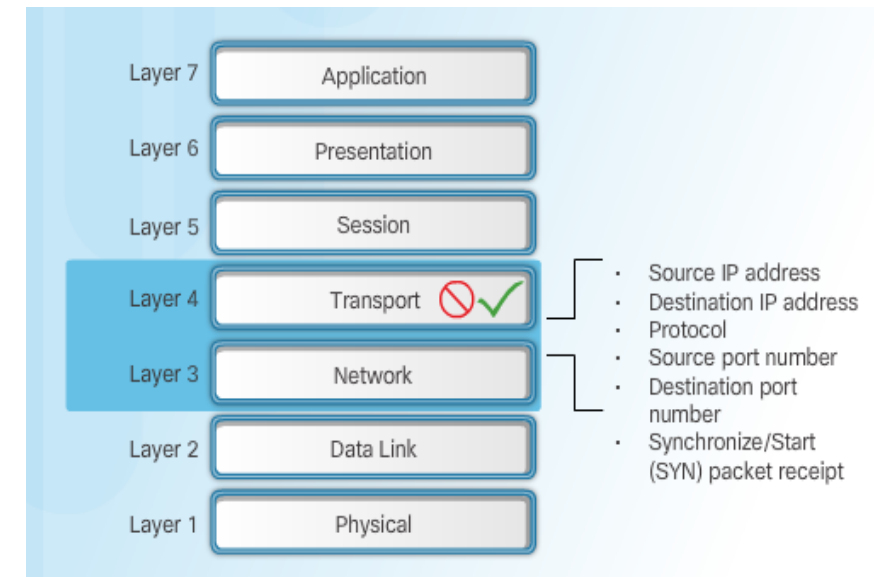
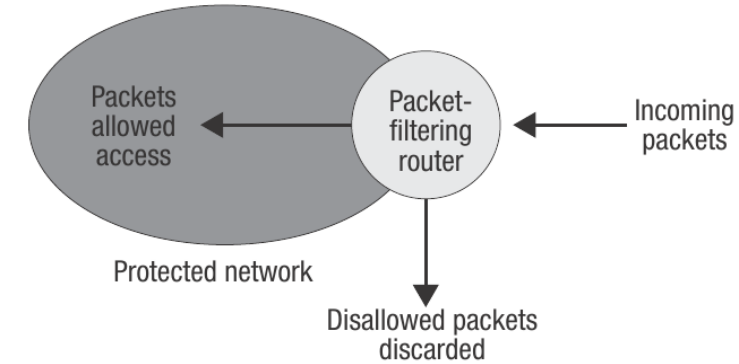
Firewall Types	
First Generation	Un ruteo simple de packet-filtering impone reglas basadas en protocolos y puertos de direcciones.
Second Generation	Realiza un seguimiento de todas las conexiones en una tabla de estado
Thrid Generation	Opera en L7 y puede examinar el protocolo real que se utiliza para las comunicaciones, como HTTP
Next Generation	A veces llamada deep packet inspection : es una mejora de los FW de 3era generación con la funcionalidad de un IPS y, a menudo, inspecciona las conexiones SSL o SSH

Information Flow Control

Packet Filtering Firewall

Los firewalls de primera generación eran firewalls **basados en filtrado de paquetes** implementados entre la red privada e Internet.

En el **filtrado de paquetes**, un router de detección examina el encabezado de cada paquete de datos que viaja entre Internet y la red corporativa. Los encabezados de los paquetes contienen información, incluida la dirección IP del emisor y el receptor, junto con los números de puerto (aplicación o servicio) autorizados para usar la información transmitida. En **función de esa información**, el router **sabe** qué tipo de servicio de Internet se está utilizando para enviar datos, así como las identidades del emisor y receptor de los datos. Entonces, el router puede evitar que ciertos paquetes se envíen entre Internet y la red corporativa.



Information Flow Control

Packet Filtering Firewalls

Los FW de filtrado de paquetes son, por lo tanto, **más adecuados para redes más pequeñas**. Las organizaciones con muchos routers pueden tener dificultades para diseñar, codificar y mantener la base de reglas. Debido a que sus reglas de **filtrado se realizan** en la **capa de transporte y red**, los firewalls de filtrado de paquetes **generalmente son estables y simples**

Exhibit 3.10: Packet Filtering Firewalls	
Advantages	Disadvantages
Simplicity of one network “choke point”	Vulnerable to attacks from improperly configured filters
Minimal impact on network performance	Vulnerable to attacks tunneled over permitted services
Inexpensive or free	All private network systems vulnerable when a single packet filtering router is compromised

Source: CSX Cybersecurity Fundamentals, Study Guide, 2nd Edition

Para estas ventajas y desventajas, el filtrado de paquetes es más efectivo cuando se implementa con la seguridad y el monitoreo básicos en mente.

Algunos de los ataques más comunes contra los firewalls de filtro de paquetes son: IP spoofing, Source routing specification, Miniature fragment attack.

Stateful Inspection Firewalls

También conocido como **filtrado dinámico de paquetes**, rastrea la dirección IP de destino de cada paquete que sale de la red interna de la organización. Cada vez que se recibe una respuesta a un paquete, se hace referencia a su registro para determinar si el mensaje recibido se realizó en respuesta a una solicitud enviada por la organización. Este enfoque evita cualquier **ataque iniciado y originado por un extraño**.

A diferencia de los FW de aplicaciones, los **FW de inspección con estado proporcionan control** sobre el **flujo** de tráfico IP. Lo hacen haciendo coincidir la información contenida en los encabezados de los paquetes IP (orientados a conexión o sin conexión) en la capa de transporte con un conjunto de reglas autorizadas por la organización.

Exhibit 3.12: Stateful Inspection Firewalls	
Advantages	Disadvantages
Provide greater control over the flow of IP traffic	Complex to administer
Greater efficiency in comparison to CPU-intensive, full-time application firewall systems	

Information Flow Control

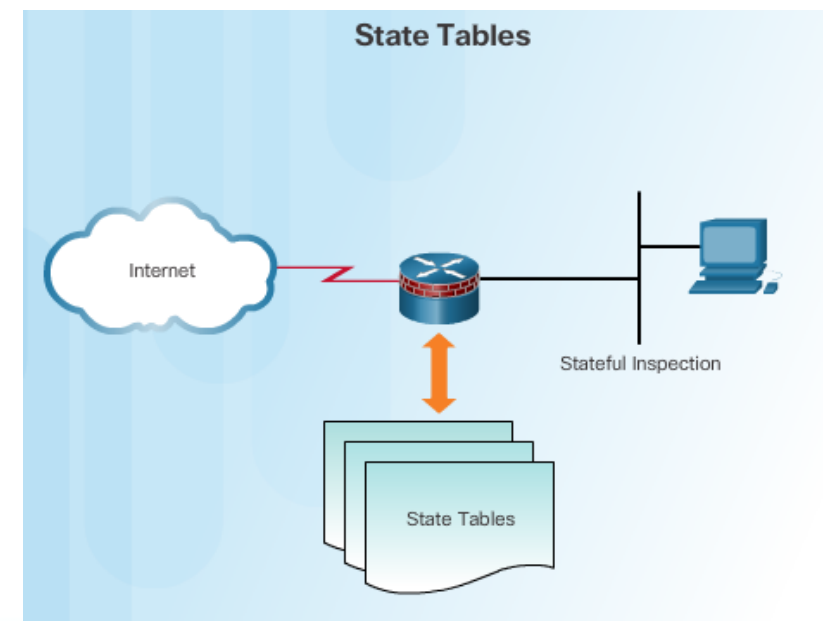
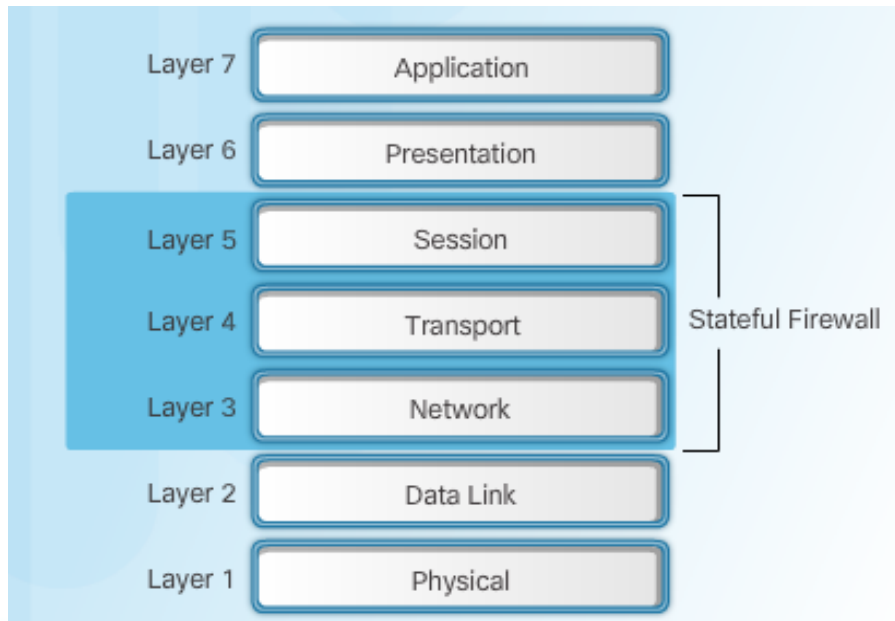
Stateless VS. Stateful

El filtrado sin estado no mantiene el estado de las sesiones de conexión TCP en curso.

En otras palabras, **no tiene memoria de los números de puerto de origen** que seleccionó el cliente de las sesiones.

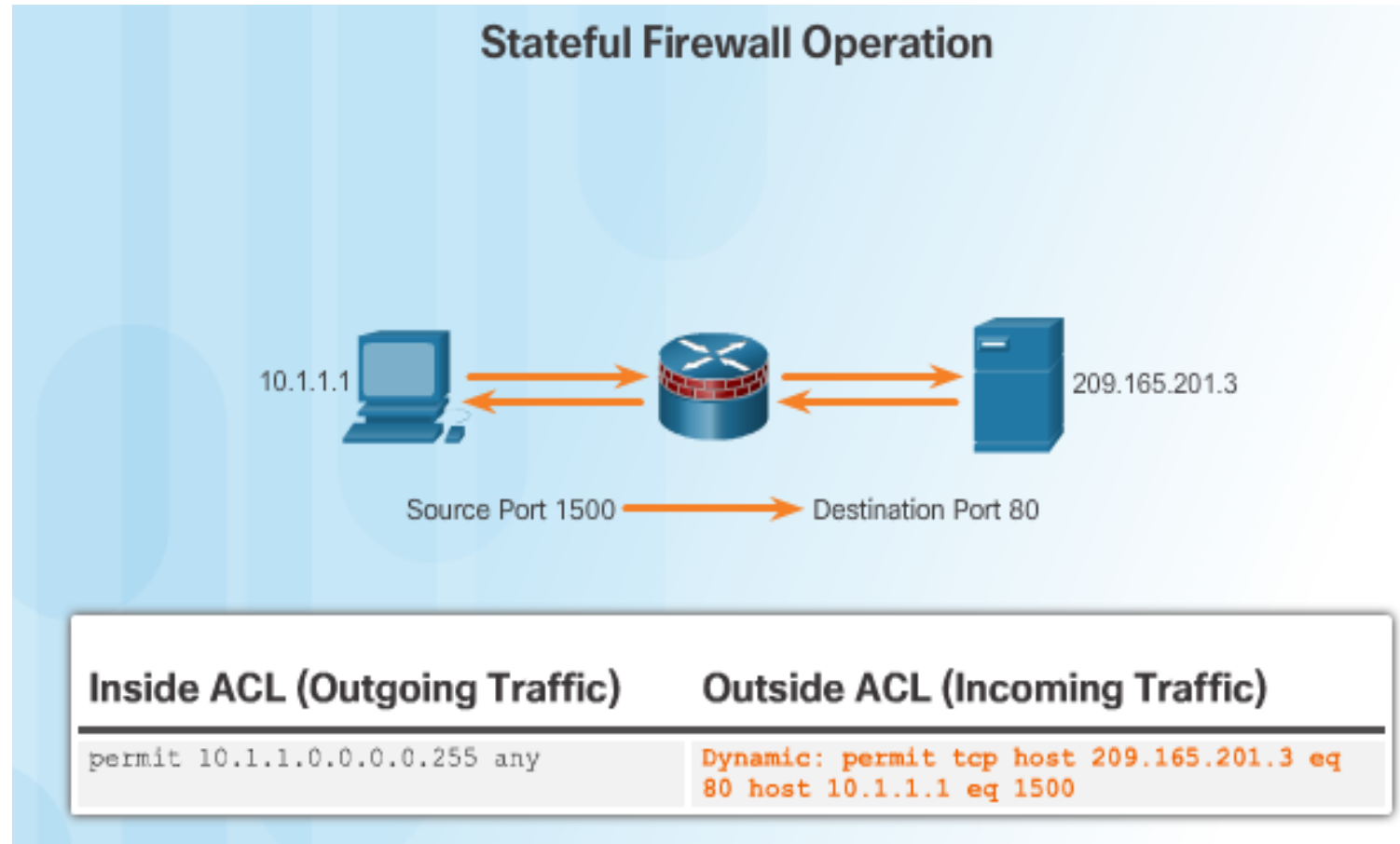
Los servidores de seguridad con estado **mantienen un registro de las conexiones TCP**.

El firewall mantiene una entrada en un caché para cada conexión TCP abierta. Los firewalls sin estado **funcionan más rápidamente** que los firewalls con estado, pero no son tan sofisticados.



Information Flow Control

Stateful Inspection Firewalls



Application Firewall

Packet Filtering Firewall protects layers 3 and 4. Stateful inspection firewall protect layers 3, 4 and 5. But if the application (server/client) (Layers 7) is malicious or has an anomalous nobody can detect it!

So, a Firewall that can be able to protect Layer 7 is born. This is the **APPLICATION FIREWALL!**

Two types of Application Firewall:

1. **Application-level gateways:** Analyze packets using a set of proxies (One for each service/protocol). So this firewall is composed of HTTP proxy, FTP proxy, etc...
2. **Circuit-level gateways:** Analyze packets using ONE single proxy for all services/protocols.

Exhibit 3.11: Application Firewalls	
Advantages	Disadvantages
Provide security for commonly used protocols	Poor performance and scalability as Internet usage grows
Generally hide the network from outside untrusted networks	
Ability to protect the entire network by limiting break-ins to the firewall itself	
Ability to examine and secure program code	

Information Flow Control

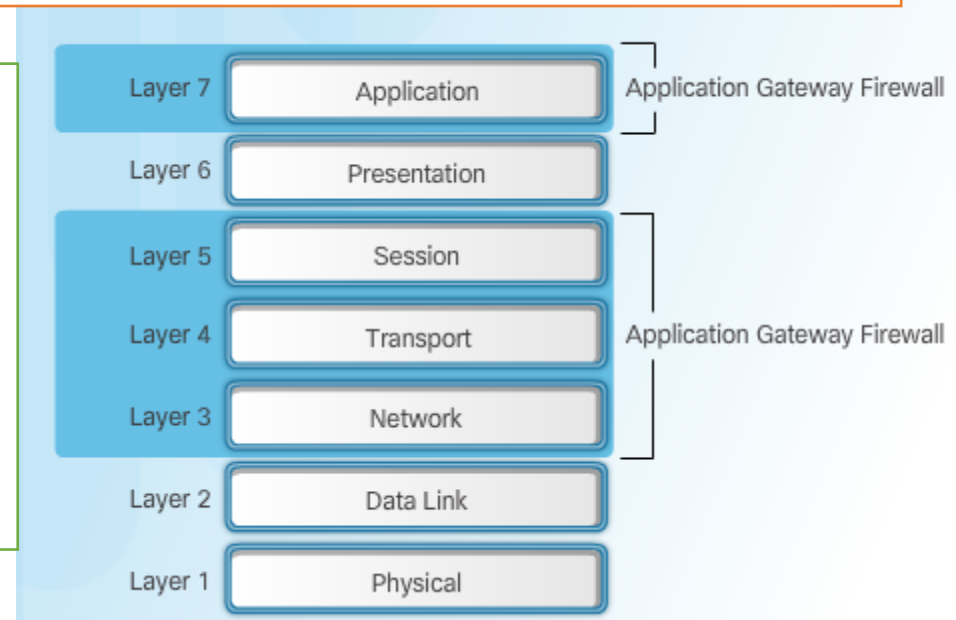
Application Firewall

Application firewall are set as a PROXY SERVER, so all users inside the network have to pass by him to access internet.

When someone inside the corporate network wants to access a server on the Internet, a request from the computer is sent to the proxy server. The proxy server contacts the Internet server, and the proxy server then sends the information from the Internet server to the computer inside the corporate network.

The application firewall:

1. Maintain security by examining the program code of a given service/protocol
2. It modifies and secures service/protocols to eliminate known vulnerabilities
3. Log all traffic between the Internet and the inside network
4. It has NAT (Network Address Translation) capabilities



Information Flow Control

Web Application Firewalls

Un firewall de aplicaciones web (WAF) es un complemento de servidor, dispositivo o filtro adicional que se puede usar para aplicar reglas a una aplicación web específica (generalmente a una conversación HTTP).

Opera en los niveles superiores del modelo OSI, generalmente **L7**, mientras que los firewalls de red operan en el nivel 3 y / o nivel 4.

Se puede personalizar para **identificar y bloquear** muchos tipos de ataques, como scripts de sitios cruzados (**XSS**) y la inyección estructurada de consulta (**iSQL**).

La personalización de las reglas de WAF requiere mucho trabajo y esfuerzo. Cuando se **realizan cambios** en la aplicación, **las reglas** de WAF **deben cambiarse también**

Information Flow Control

Next Generation Firewalls

NGFW son el tipo más nuevo de firewall y resuelven dos limitaciones de las generaciones anteriores de firewalls:

1. Incapacidad de inspeccionar la carga útil del paquete
2. Incapacidad de distinguir entre tipos de tráfico web

Un NGFW es un sistema de seguridad de red adaptable capaz de :

1. Realizar funciones tradicionales como filtrado de paquetes, inspección de estado y traducción de direcciones de red (NAT)
2. Detectar y bloquear ataques sofisticados
3. Incorporar tecnología DPI (Deep Packet Inspection)
4. Implementa DLP (Data Loss Prevention), IPS (Intrusion Prevention system), inspection SSL / SSH and web filtering using reputation
5. Incorpora Application Awareness

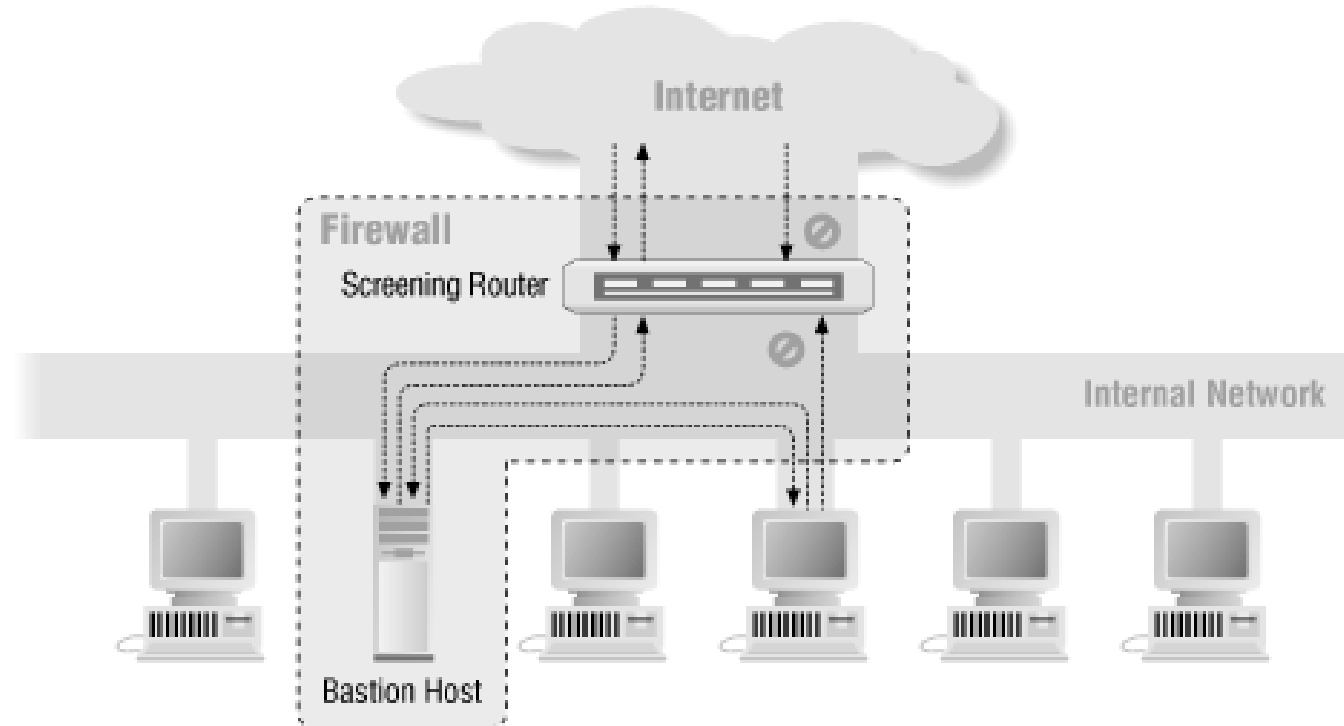
Application Awareness:

- Maintain information about connected applications to optimize their operation
- Allow granular identification, visibility, and control of behaviors within applications
- So, corporate policies can be enforced independent of port or protocol

Information Flow Control

Examples of Firewall Implementations

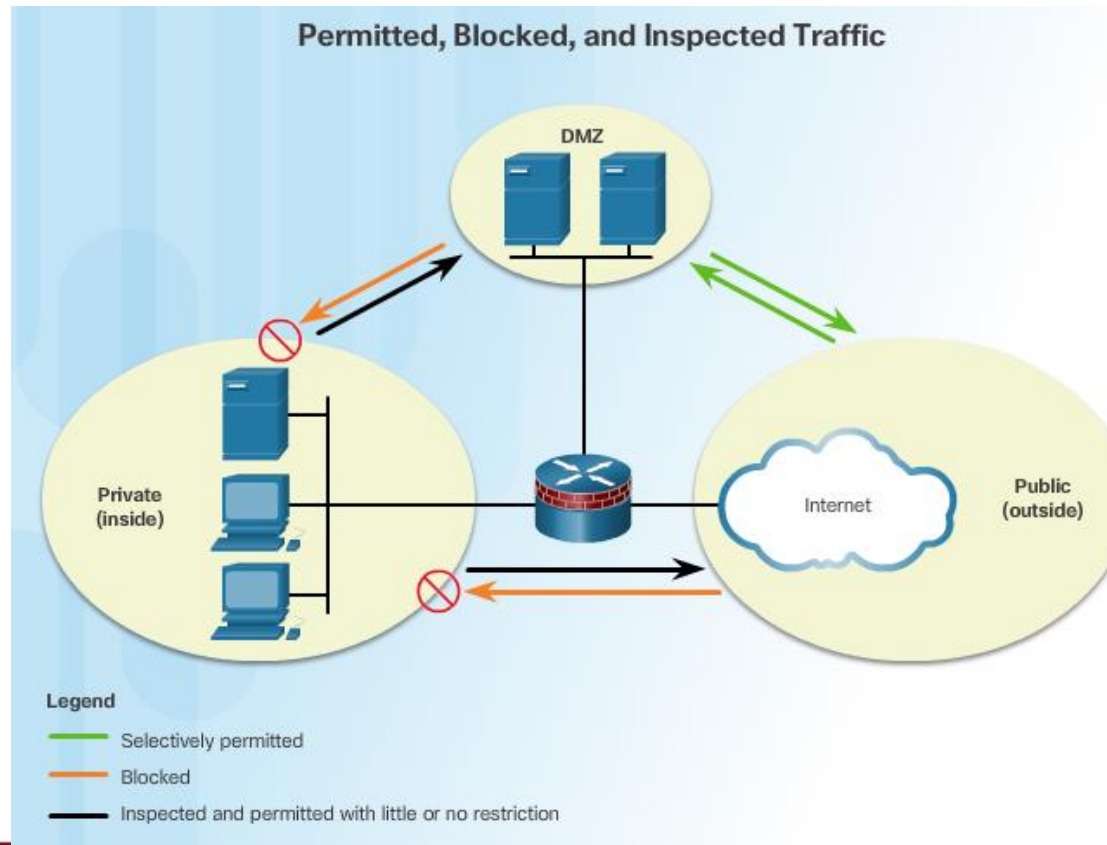
- **Screened- host Firewall:** It uses i) one Packet Filtering Router and ii) one bastion Host



Information Flow Control

Examples of Firewall Implementations

- **Demilitarized zone (DMZ) or screened-subnet Firewall** (red pequeña y aislada para los servidores públicos de una organización)



Information Flow Control

Firewall Issues

Configuration errors may provoke serious incidents

Monitoring a firewall is tedious labor



Firewalls from generation 1 (L3/L4) and generation 2 (L3/L4/L5) do not avoid application attacks (SQL injection, Buffer overflow, etc)

Firewall policies need to be maintained

Information Flow Control

Firewall Platforms

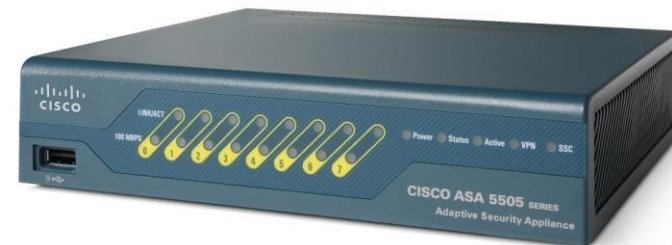
Los FW pueden implementarse utilizando plataformas de hardware o software

La implementación de **HW** proporcionará rendimiento con una sobrecarga mínima del sistema pero no son tan flexibles ni escalables como los firewalls basados en SW.

Es mejor usar dispositivos diseñados específicamente para cumplir la función de Firewall, en lugar de servidores normales.

Estos dispositivos traen sistemas operativos reforzados. Cuando se utilizan firewalls basados en servidor, los sistemas operativos en los servidores suelen ser vulnerables a los ataques.

Los firewalls basados en **SW** generalmente son más lentos con una sobrecarga significativa de los sistemas. Sin embargo, son flexibles con servicios adicionales.



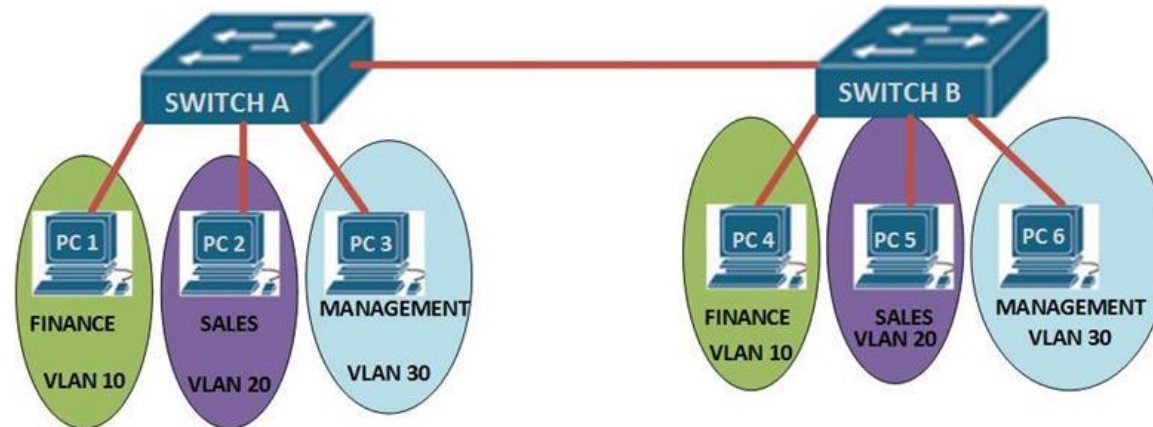
Agenda

- 1 Overview of security architecture
- 2 The OSI model
- 3 Defense in depth
- 4 Information flow control
- 5 Isolation and segmentation
- 6 Loggin, monitoring and detection
- 7 Encryption fundamentals, techniques and applications

Isolation and Segmentation

Virtual Local Area Networks

Una técnica común para implementar la seguridad de la red es segmentar la red de una organización para que cada segmento pueda controlarse, monitorearse y protegerse por separado.



Al ser conexiones lógicas permite una gran flexibilidad. Esta flexibilidad permite a los administradores segmentar los recursos de la red para un rendimiento óptimo al restringir el acceso de los usuarios de los recursos de la red únicamente a las personas necesarias.

Isolation and Segmentation

Security Zones and Demilitarized Zones

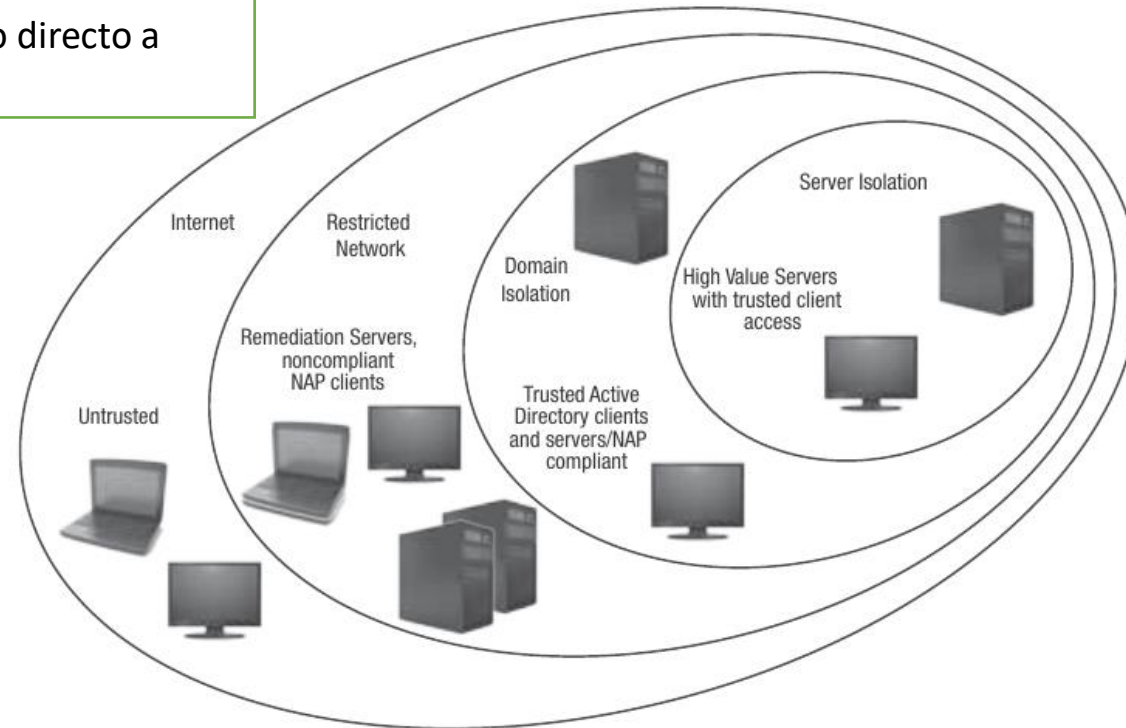
Beneficios de tener zonas de seguridad:

1. Un intruso debe penetrar en tres dispositivos separados
2. Las direcciones de red privada no se divulgan a Internet
3. Los sistemas internos no tienen acceso directo a Internet

Al crear **zonas separadas**, los controles se pueden aplicar a un nivel más granular en función de los sistemas, la información y las aplicaciones en cada área.

Las zonas separadas pueden crear defensas en profundidad donde pueden tener lugar **capas adicionales de autenticación, control de acceso y monitoreo.**

Los sistemas, servicios y servidores web que deben estar disponibles fuera de la red interna se despliegan en un segmento de red llamado zona desmilitarizada (DMZ)



Source: CSX Cybersecurity Fundamentals, Study Guide, 2nd Edition

Agenda

- 1 Overview of security architecture
- 2 The OSI model
- 3 Defense in depth
- 4 Information flow control
- 5 Isolation and segmentation
- 6 Loggin, monitoring and detection
- 7 Encryption fundamentals, techniques and applications

Logging, Monitoring and Detection

El monitoreo, la detección y el registro son parte integral de la ciberseguridad

Logging

Un **log** es un registro de eventos que ocurren dentro de los sistemas y redes de una organización. Los logs son una de las herramientas más valiosas para **monitorear los controles y detectar riesgos**, pero a menudo son subutilizados.

Un log registra **todos los eventos** importantes que ocurren en un sistema, por ejemplo

1. Cambios a los permisos
2. Arranque o apagado del sistema
3. Iniciar sesión o cerrar sesión
4. Cambios en los datos
5. Errores o violaciones
6. Fallas de trabajo

Los desafíos comunes relacionados con el uso efectivo de los registros incluyen:

- Tener demasiados datos
- Dificultad para buscar
- Configuración incorrecta
- Modificación o eliminación de datos antes de que se lean

SIEM (Security Information and Event Management)

Funcionalidades de tecnologías SIEM:

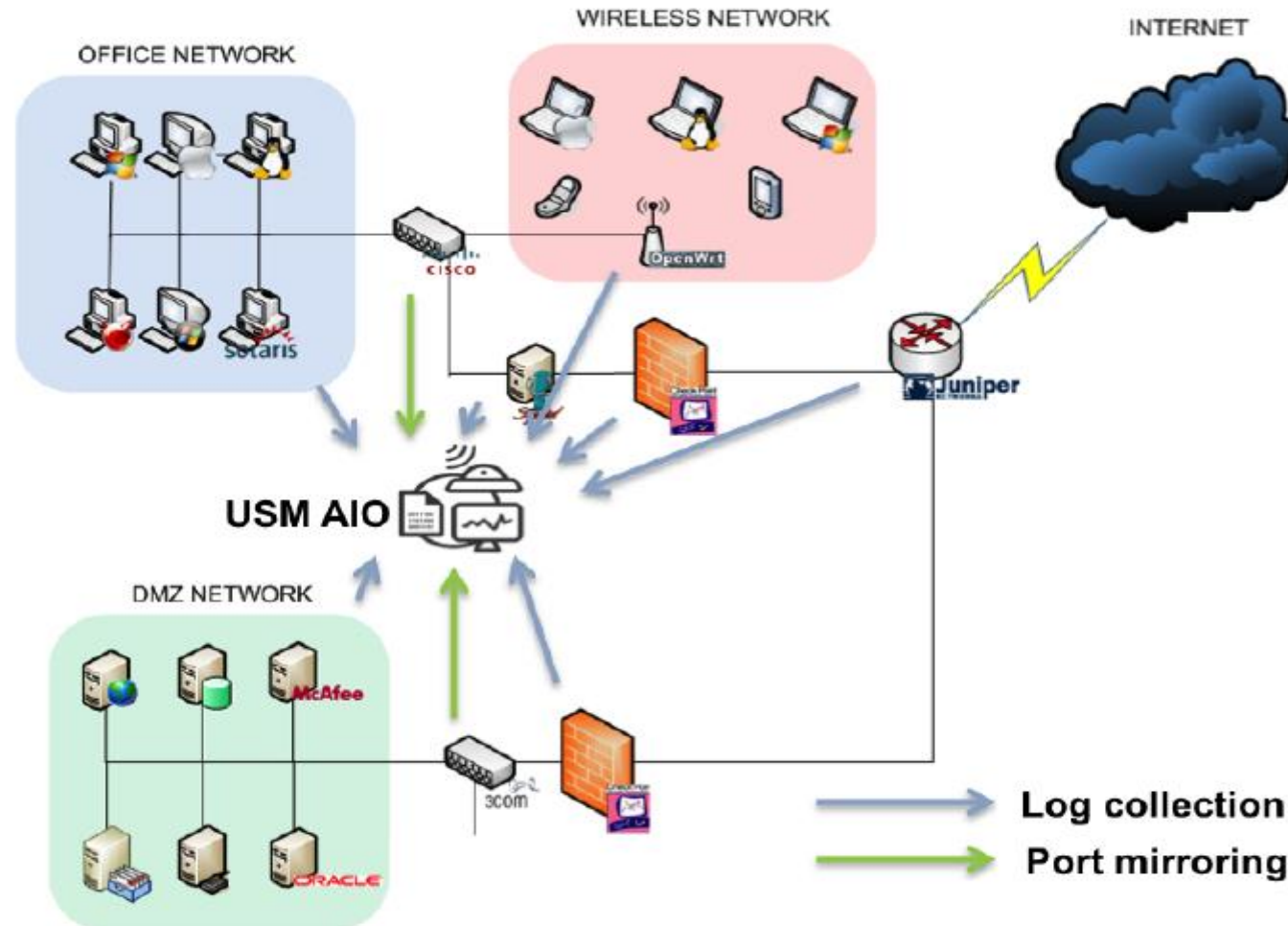
- SIM — Security Information Management: Gestión de logs, análisis y reportes de cumplimiento.
- SEM — Security Event Management: Monitoreo en tiempo real y gestión de incidentes para eventos de seguridad en redes, dispositivos de seguridad, sistemas y aplicaciones.

Casos de uso:

- Gestión de amenazas: Monitoreo en tiempo real y reporte de actividades de usuario, acceso a datos, actividad en la aplicación, en combinación con capacidades de consulta.
- Cumplimiento: Gestión de logs y reportes de cumplimiento
- Un despliegue SIEM que provee una mezcla de gestión de amenazas y capacidades de cumplimiento

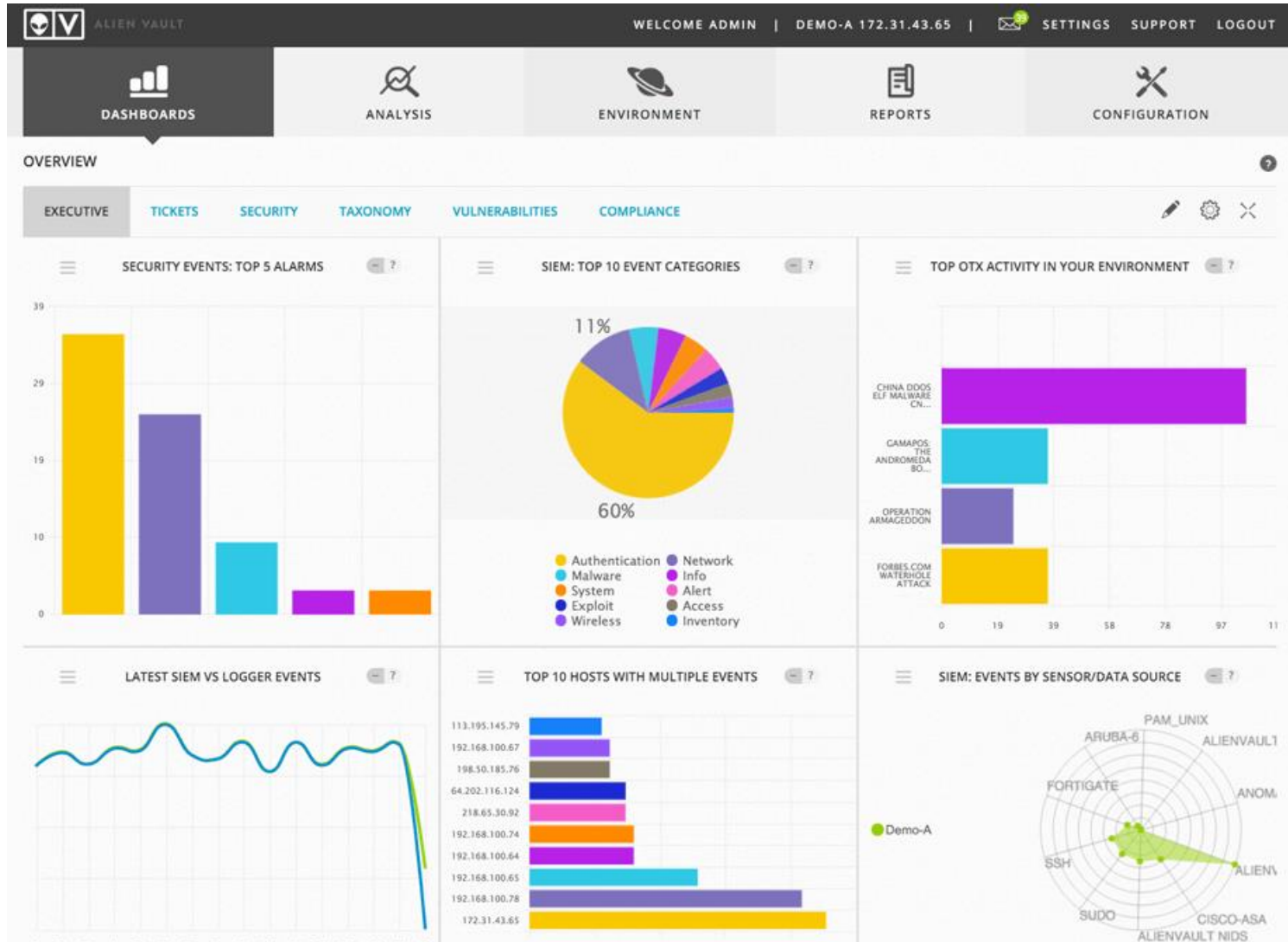
Logging, Monitoring and Detection

SIEM (Security Information and Event Management)



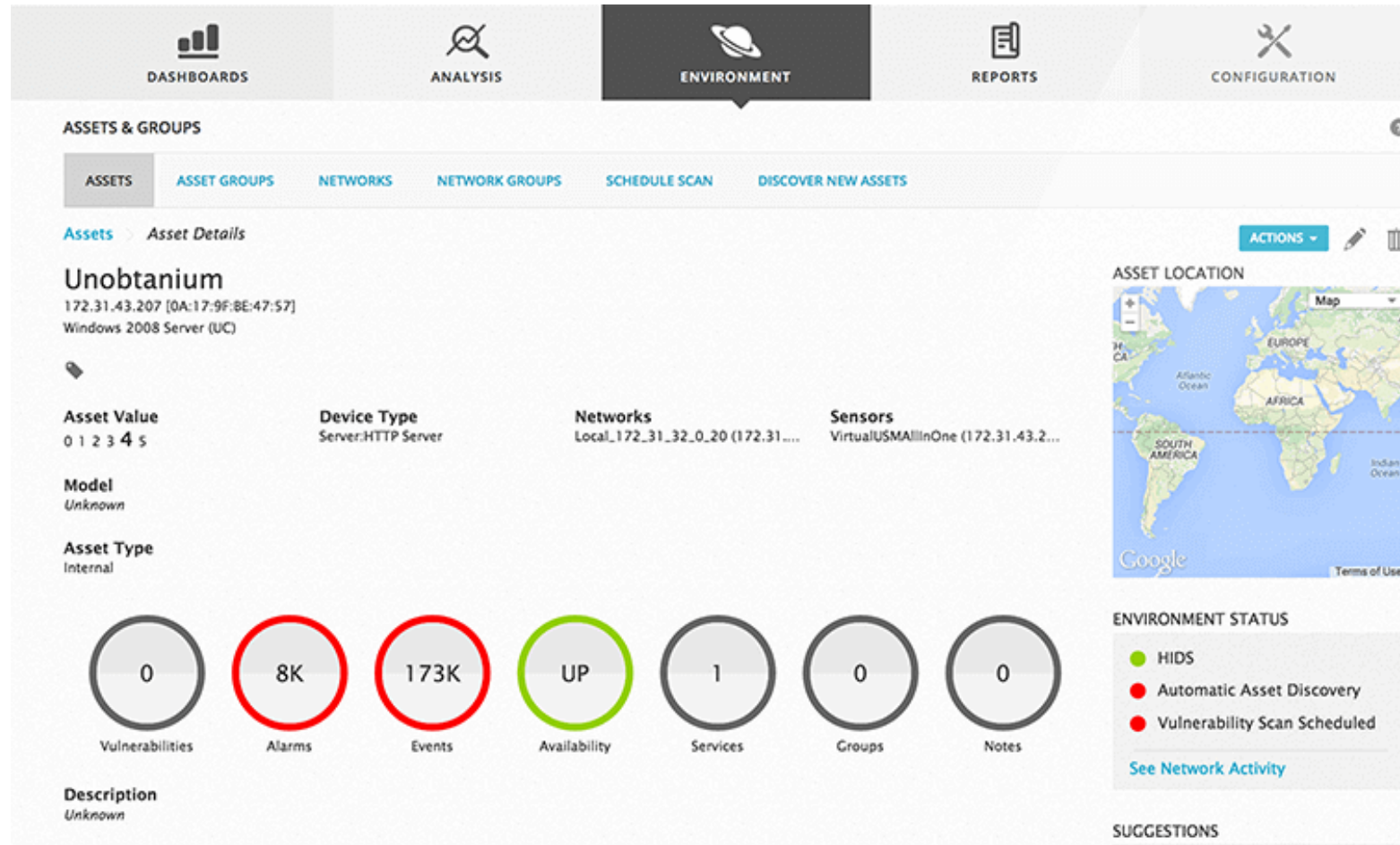
Logging, Monitoring and Detection

SIEM (Security Information and Event Management)



Logging, Monitoring and Detection

SIEM (Security Information and Event Management)



Logging, Monitoring and Detection

SIEM (Security Information and Event Management)

Displaying events 151-200 of about hundreds matching your selection.									829 total events in database.	
☐	Signature	▼ Date GMT-4:00 ▲	Device	Userdata1	Userdata2	Userdata3	Userdata4	Userdata5	Src IP	Dst IP
	☐ suricata-dns: Query	2013-09-17 23:15:01	10.49.5.204	reputation.alienvault.com	TX	A	Empty	Empty	10.49.5.204	8.8.8.8
	☐ suricata-dns: Response	2013-09-17 23:15:01	10.49.5.204	reputation.alienvault.com	TX	A	176.9.232.131	3021	8.8.8.8	10.49.5.204
	☐ suricata-dns: Response	2013-09-17 23:15:01	10.49.5.204	reputation.alienvault.com	TX	A	176.9.232.147	3021	8.8.8.8	10.49.5.204
	☐ suricata-dns: Query	2013-09-17 23:15:01	10.49.5.204	reputation.alienvault.com	TX	AAAA	Empty	Empty	10.49.5.204	8.8.8.8
	☐ suricata-dns: Query	2013-09-17 23:00:01	10.49.5.204	static.nvd.nist.gov	TX	AAAA	Empty	Empty	10.49.5.204	8.8.8.8
	☐ suricata-dns: Response	2013-09-17 23:00:01	10.49.5.204	nvd.nist.gov	TX	A	129.6.13.18	403	8.8.8.8	10.49.5.204
	☐ suricata-dns: Response	2013-09-17 23:00:01	10.49.5.204	static.nvd.nist.gov	TX	CNAME	nvd.nist.gov	403	8.8.8.8	10.49.5.204
	☐ suricata-dns: Query	2013-09-17 23:00:01	10.49.5.204	static.nvd.nist.gov	TX	A	Empty	Empty	10.49.5.204	8.8.8.8
	☐ suricata-dns: Query	2013-09-17 22:34:38	10.49.5.204	reputation.alienvault.com	TX	A	Empty	Empty	10.49.5.204	8.8.8.8
	☐ suricata-dns: Response	2013-09-17 22:34:38	10.49.5.204	reputation.alienvault.com	TX	A	176.9.232.131	2616	8.8.8.8	10.49.5.204
	☐ suricata-dns: Response	2013-09-17 22:34:38	10.49.5.204	reputation.alienvault.com	TX	A	176.9.232.147	2616	8.8.8.8	10.49.5.204
	☐ suricata-dns: Query	2013-09-17 22:34:38	10.49.5.204	reputation.alienvault.com	TX	AAAA	Empty	Empty	10.49.5.204	8.8.8.8
	☐ suricata-dns: Response	2013-09-17 22:34:35	10.49.5.204	alienvault.com	TX	SOA	www.alienvault.com	14	8.8.8.8	10.49.5.204
	☐ suricata-dns: Query	2013-09-17 22:34:35	10.49.5.204	reputation.alienvault.com	TX	AAAA	Empty	Empty	10.49.5.204	8.8.8.8
	☐ suricata-dns: Response	2013-09-17 22:34:35	10.49.5.204	reputation.alienvault.com	TX	A	176.9.232.147	2620	8.8.8.8	10.49.5.204
	☐ suricata-dns: Response	2013-09-17 22:34:35	10.49.5.204	reputation.alienvault.com	TX	A	176.9.232.131	2620	8.8.8.8	10.49.5.204
	☐ suricata-dns: Query	2013-09-17 22:34:35	10.49.5.204	reputation.alienvault.com	TX	A	Empty	Empty	10.49.5.204	8.8.8.8

Logging, Monitoring and Detection

Data Loss Prevention (DLP)

Hay dos tipos de vectores de ataque:

- i) Ingreso
- ii) Egreso (también conocido como exfiltración de datos)

Un programa de prevención de pérdida de datos exitoso ayuda a una organización a proteger su información y evitar la exfiltración de datos confidenciales.

DLP

Soluciones DLP
robustas cubren los tres
estados principales de
los datos

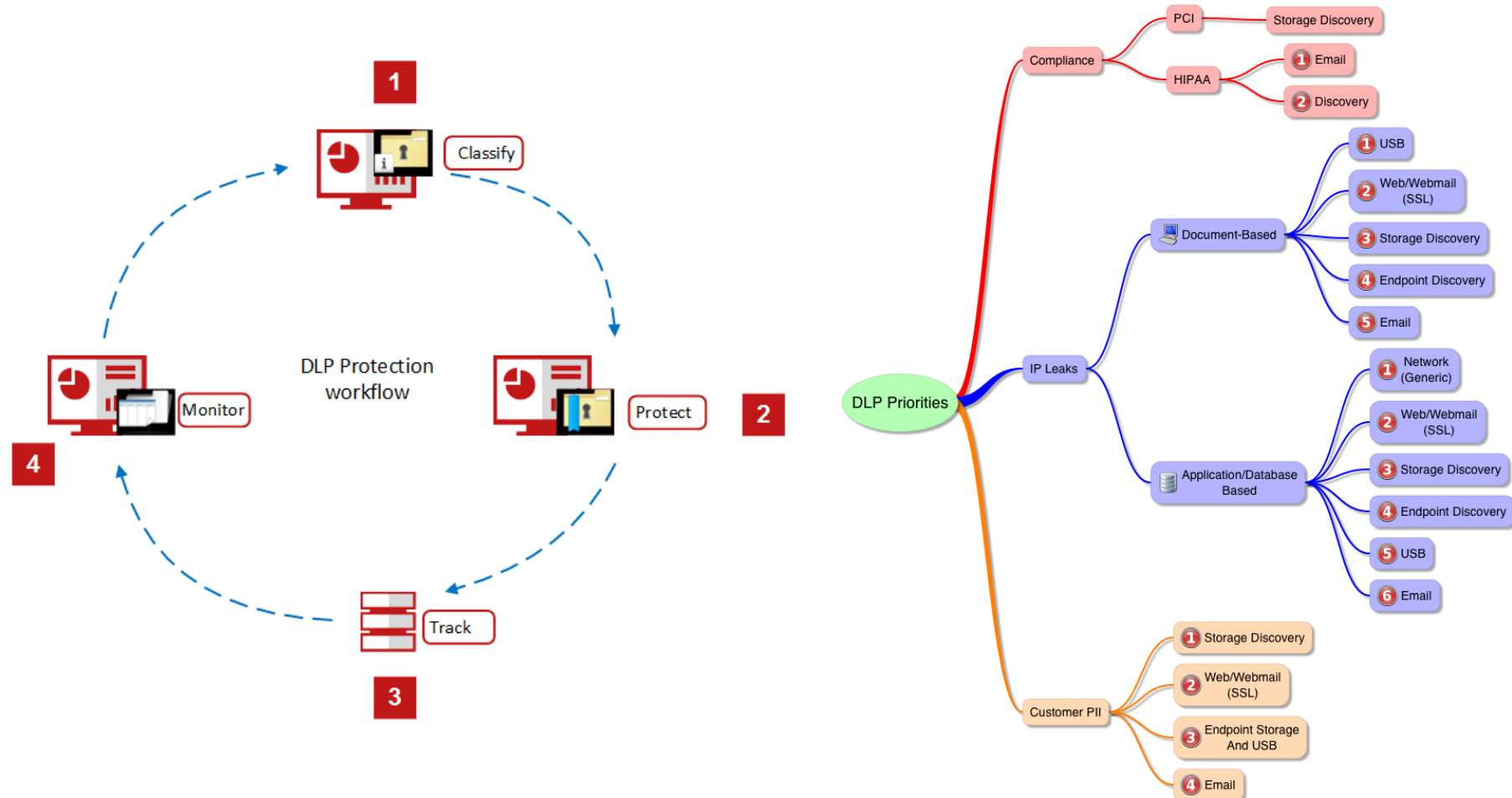
Datos en reposo se refieren a los datos almacenados

Datos en uso, que es el movimiento de datos en el nivel de estación de trabajo del usuario

Datos en tránsito hacen referencia a los datos que viajan a través de la red

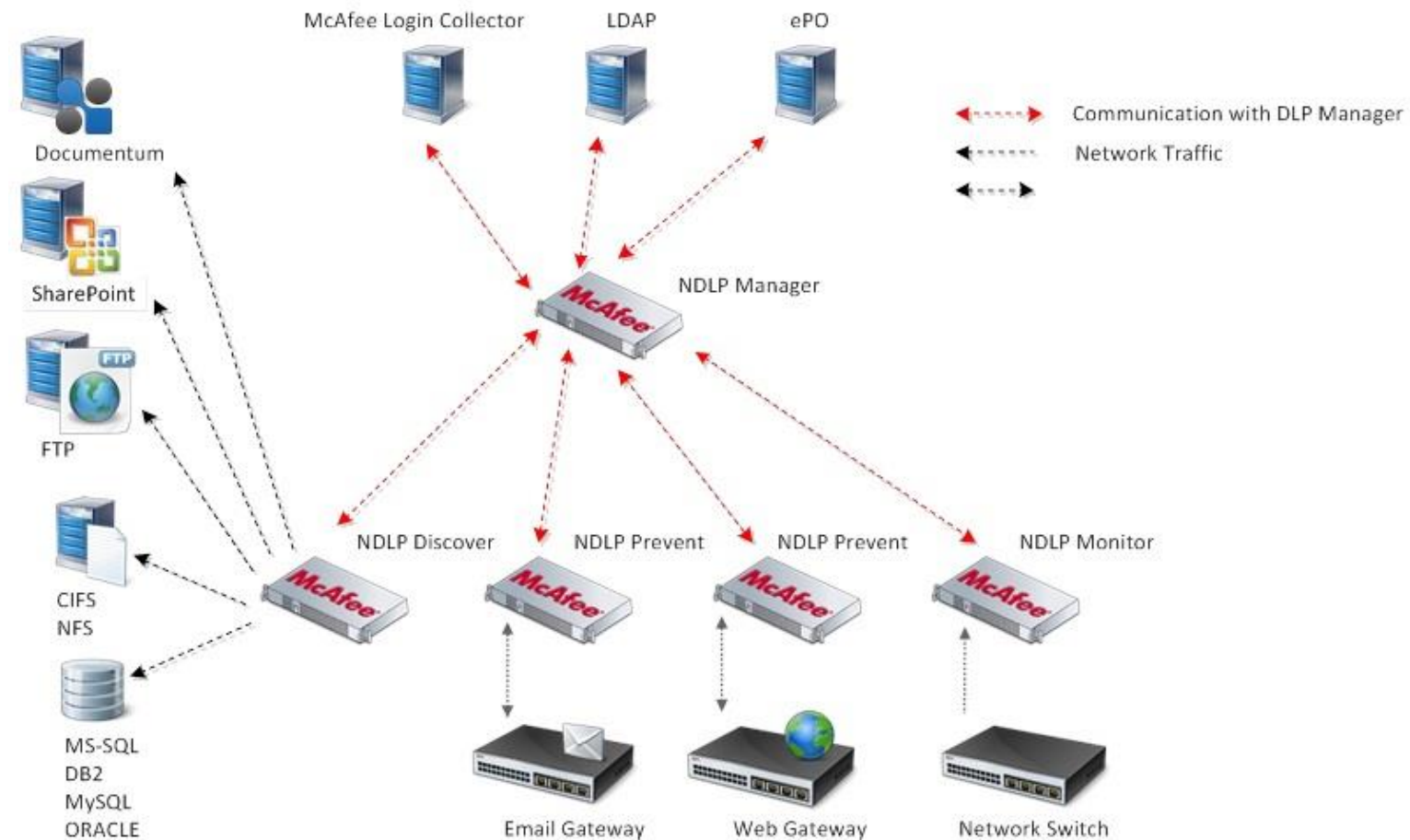
Logging, Monitoring and Detection

Data Loss Prevention (DLP)



Logging, Monitoring and Detection

Data Loss Prevention (DLP)



ESCUELA
COLOMBIANA
DE INGENIERÍA
JULIO GARAVITO

UNIVERSIDAD

DLP Endpoint Console

-||x

Events History
Discovery
Tasks
About

DLP Endpoint

Scan Type	Status	Start date	Duration	Time to complete
Email Storage	Completed	28.1.2014, 11:01	00:00:00	00:00:00
Local File System	Not configured	-	-	-

Scan Details	Files found by scan
Details for Local File System	
Status: Start date: Next scan: Duration: Time to complete: Estimated files to scan:	File Totals Scanned: Quarantined: Tagged: Monitored: Encrypted: Deleted: Protected by RM:

Logging, Monitoring and Detection

Data Loss Prevention (DLP)

ePolicy Orchestrator 5.3.1

https://192.168.1.250:8443/core/orionTab.do?sectionId=DataProtection&tabId=udlp.ruleSet.manager&orion.user.security.token=K4o7hzq4raa0dy6G

ePolicy Orchestrator System Tree Dashboards DLP Policy Manager Classification DLP Incident Manager TIE Reputations Log Off ?

Data Protection

DLP Policy Manager

☒ Show built-in rule sets samples

Rule Set	Incidents	Data Rules	Device Rules	Discovery Rules	Last Modified (UTC)	Modified by	Actions
[Sample] How to Block & Monitor Social Media We	0	1/1	0/0	0/0	July 6, 2016 5:29:42 PM	admin	duplicate
[Sample] How to Block CD/DVD Burner Application	0	1/1	0/0	0/0	July 6, 2016 5:29:42 PM	admin	duplicate
[Sample] How to Block smartphones [built-in]	0	0/0	1/1	0/0	July 6, 2016 5:29:43 PM	admin	duplicate
[Sample] How to Educate users on emailing sensit	0	1/1	0/0	0/0	July 6, 2016 5:29:43 PM	admin	duplicate
[Sample] How to identify cloud services in use by	0	1/1	0/0	0/0	July 6, 2016 5:29:44 PM	admin	duplicate
[Sample] How to identify social networks in use b	0	2/2	0/0	0/0	July 6, 2016 5:29:44 PM	admin	duplicate
[Sample] How to Make USB devices Read-Only, Bl	0	0/0	2/2	0/0	July 6, 2016 5:29:42 PM	admin	duplicate
[Sample] How to Monitor Confidential Data Uploa	0	2/2	0/0	0/0	July 6, 2016 5:29:42 PM	admin	duplicate
[Sample] How to Monitor Database Files [built-in]	0	4/4	0/0	0/0	July 6, 2016 5:29:42 PM	admin	duplicate
[Sample] How to protect emailing of confidential c	0	2/2	0/0	0/0	July 6, 2016 5:29:43 PM	admin	duplicate
[Sample] How to Protect Terminal Server Data [bu	0	3/3	0/0	0/0	July 6, 2016 5:29:42 PM	admin	duplicate
[Sample] Manage PnP and Removable storage dev	0	0/0	2/3	0/0	July 6, 2016 5:29:41 PM	admin	duplicate
[Sample] Monitor Classified content [built-in]	0	7/7	0/0	0/0	July 6, 2016 5:29:42 PM	admin	duplicate
[Sample] Monitor Export Administration Regulatio	0	7/7	0/0	0/0	July 6, 2016 5:29:44 PM	admin	duplicate
[Sample] Monitor HIPAA content [built-in]	0	7/7	0/0	1/1	July 6, 2016 5:29:40 PM	admin	duplicate
[Sample] Monitor ITAR content [built-in]	0	7/7	0/0	1/1	July 6, 2016 5:29:41 PM	admin	duplicate
[Sample] Monitor PCI DSS content [built-in]	0	7/7	0/0	1/1	July 6, 2016 5:29:40 PM	admin	duplicate

Choose Columns

New Rule Set

Actions 42 items

Windows Taskbar: ePolicy Orchestrator ... 10:15 PM

Logging, Monitoring and Detection

Data Loss Prevention (DLP)

The screenshot shows the ePolicy Orchestrator 5.3.1 web interface. The browser address bar displays the URL: `https://192.168.1.250:8443/core/orionTab.do?sectionId=DataProtection&tabId=classific.classification&orion.user.security.token=K4o7hzq4raa0dy6G`. The navigation bar includes links for System Tree, Dashboards, DLP Policy Manager, Classification, DLP Incident Manager, and TIE Reputations. The main content area is titled 'Data Protection Classification'. A red box highlights the 'Manual Classification' tab. Below the tabs, there is a 'View: Group by classifications' dropdown. The left sidebar shows a list of classifications, with 'Autocad Document Classification (0)' selected. The right pane displays the details for 'Autocad Document Classification', including a description, additional actions (Manual classification and Content fingerprinting), and end-user groups. The bottom status bar shows the time as 10:15 PM.

Logging, Monitoring and Detection

Data Loss Prevention (DLP)

The screenshot displays the McAfee ePolicy Orchestrator 5.1.1 interface, specifically the DLP Incident Manager section. The interface is divided into several components:

- Navigation Menu:** Includes options like Dashboards, System Tree, TIE Reputations, Queries & Reports, Policy Catalog, Server Tasks, and Server Task Log.
- Incident Manager Header:** Shows the title 'Data Protection DLP Incident Manager' and tabs for Incident List, Incident Tasks, and Incident History.
- Filtering and View Options:** Includes a 'Present' dropdown set to 'Data in-use/motion', a 'View' dropdown set to 'Default', and a 'Time' dropdown set to '(no time filter)'. There are also buttons for 'Edit', 'Delete', and 'Save'.
- Incident List Table:** A table with 20 rows, each representing an incident. The columns are: Incident ID, Occurred..., Severity, Incident Type, User Account, Computer Name, Actual Action, Rules, and Classifications. All incidents have a severity of 'Major (3)' and an action of 'Block'.
- Footer:** Includes a status bar showing '20 items in 2 pages' and a 'Go to page' dropdown set to '1'.

Incident ID	Occurred...	Severity	Incident Type	User Account	Computer Name	Actual Action	Rules	Classifications
20	2015/06/29 05:57...	Major (3)	Application File Ac...	WIN81VPN\Ted_2	WIN81VPN	Block	Prevent SSN from...	Contains Social Se...
19	2015/06/29 05:47...	Major (3)	Cloud Protection	WIN81VPN\Ted_2	WIN81VPN	Block	Prevent SSN from...	Contains Social Se...
18	2015/06/29 05:38...	Major (3)	Cloud Protection	WIN81VPN\Ted_2	WIN81VPN	Block	Cloud Protection R...	Social Security Nu...
16	2015/06/29 04:30...	Major (3)	Cloud Protection	WIN81VPN\Ted_2	WIN81VPN	Block	Cloud Protection R...	Social Security Nu...
17	2015/06/29 04:30...	Major (3)	Cloud Protection	WIN81VPN\Ted_2	WIN81VPN	Block	Cloud Protection R...	Social Security Nu...
15	2015/06/29 04:27...	Major (3)	Application File Ac...	WIN81VPN\Ted_2	WIN81VPN	Block	Application File Ac...	Social Security Nu...
14	2015/06/29 04:27...	Major (3)	Application File Ac...	WIN81VPN\Ted_2	WIN81VPN	Block	Application File Ac...	Social Security Nu...
13	2015/06/29 04:26...	Major (3)	Cloud Protection	WIN81VPN\Ted_2	WIN81VPN	Block	Cloud Protection R...	Social Security Nu...
12	2015/06/29 04:21...	Major (3)	Cloud Protection	WIN81VPN\Ted_2	WIN81VPN	Block	Cloud Protection R...	Social Security Nu...
11	2015/06/29 04:17...	Major (3)	Cloud Protection	WIN81VPN\Ted_2	WIN81VPN	Block	Cloud Protection R...	Social Security Nu...
10	2015/06/29 04:16...	Major (3)	Cloud Protection	WIN81VPN\Ted_2	WIN81VPN	Block	Cloud Protection R...	Social Security Nu...
9	2015/06/29 04:16...	Major (3)	Cloud Protection	WIN81VPN\Ted_2	WIN81VPN	Block	Cloud Protection R...	Social Security Nu...
8	2015/06/29 04:11...	Major (3)	Cloud Protection	WIN81VPN\Ted_2	WIN81VPN	Block	Cloud Protection R...	Social Security Nu...
7	2015/06/29 03:48...	Major (3)	Application File Ac...	WIN81VPN\Ted_2	WIN81VPN	Block	Application File Ac...	Social Security Nu...
6	2015/06/29 03:34...	Major (3)	Application File Ac...	WIN81VPN\Ted_2	WIN81VPN	Block	Application File Ac...	Social Security Nu...
5	2015/06/29 02:48...	Major (3)	Application File Ac...	WIN81VPN\Ted_2	WIN81VPN	Block	Application File Ac...	Social Security Nu...
1	2015/06/29 02:34...	Major (3)	Application File Ac...	WIN81VPN\Ted_2	WIN81VPN	Block	Application File Ac...	Social Security Nu...

EDR (Endpoint Detection and Response)

Definición:

Una solución **EDR** es una herramienta de seguridad diseñada para **monitorear, detectar, analizar y responder** a amenazas en los **dispositivos finales** (endpoints), como computadoras, laptops y servidores.

Funciones clave de un EDR:

- **Monitoreo continuo de endpoints**
Detecta comportamientos sospechosos en tiempo real.
- **Detección de amenazas avanzadas**
Identifica ataques como ransomware, malware sin archivos (fileless) y movimientos laterales.
- **Respuesta automatizada**
Contiene y remedia amenazas mediante aislamiento del dispositivo, eliminación de procesos o archivos maliciosos.
- **Análisis forense**
Permite investigar cómo ocurrió el ataque y qué datos fueron comprometidos.

¿En qué se diferencia de un antivirus tradicional?

Antivirus tradicional	Solución EDR
Basado en firmas	Basado en comportamiento
Reacciona al ataque	Previene, detecta y responde
Protección básica	Visibilidad y control avanzados

Intrusion Detection Systems

Un IDS funciona en conjunto con routers y firewalls al monitorear las anomalías de uso de la red. **Protege los recursos** de una empresa **del uso indebido externo e interno**. Un IDS opera continuamente en el sistema, se ejecuta en segundo plano y notifica a los administradores cuando detecta una amenaza percibida.

Las **categorías generales** de los IDS incluyen:

- IDS basados en red
- IDS basados en host (HIDS)

Los **componentes** de un IDS son:

- Sensores responsables de recopilar datos en forma de paquetes de red, archivos de registro, rastreos de llamadas del sistema, etc.
- Analizadores que reciben información de los sensores y determinan la actividad intrusiva
- Una consola de administración
- Una interfaz de usuario

Los **tipos** de IDS incluyen:

1. Basado en la **firma**: estos sistemas IDS protegen contra los patrones de intrusión detectados.
2. Basado en **estadísticas**: estos sistemas necesitan una definición integral del comportamiento conocido y esperado de los sistemas.
3. **Redes neuronales**: un IDS con esta característica supervisa los patrones generales de actividad y tráfico en la red y crea una base de datos. Es similar al modelo estadístico pero con una funcionalidad adicional de autoaprendizaje.

Intrusion Detection Systems

Las **características disponibles** en un IDS incluyen:

1. Detección de intrusos
2. Capacidad de reunir evidencia sobre actividad intrusiva
3. Respuesta automatizada (por ejemplo, terminación de la conexión, mensajes de alarma)
4. Política de seguridad
5. Interfaz con herramientas del sistema
6. Gestión de políticas de seguridad

Un IDS no puede ayudar con las siguientes **debilidades**:

1. Debilidades en la definición de la política del IDS
2. Vulnerabilidades a nivel de aplicación
3. Puertas traseras en aplicaciones
4. Debilidades en los esquemas de identificación y autenticación

Política de IDS

Una política de IDS debe **establecer las medidas** que debe tomar el personal de seguridad en caso de que se detecte un intruso. Las acciones pueden incluir:

1. Terminar el acceso
2. Rastrear el acceso

Logging, Monitoring and Detection

Intrusion Detection Systems

Suricata Dashboard



Logging, Monitoring and Detection

Intrusion Prevention Systems

Los IPS no solo detecta sino que También previene. Por ejemplo un IPS puede:

1. Detectar ataques
2. Evitar que un programa malicioso elimine archivos en un directorio del Sistema
3. Limitar el daño o la interrupción de los sistemas atacados

Un IPS puede constituir en sí mismo una amenaza?

Si, ya que un atacante inteligente podría **enviar** comandos a un **gran número** de hosts protegidos por un IPS con el fin de provocar que el IPS aplique una medida de respuesta automática (por ejemplo aislamiento) y los vuelva **disfuncionales**.

Algunas de las **ventajas** de IPS incluyen:

- **Protección** en la capa de aplicación
- **Prevención** de ataques en lugar de simplemente reaccionar ante ellos
- **Defensa** en profundidad
- **Correlación** de eventos en tiempo real

Los IPS pueden generar **falsos positivos** que pueden crear problemas graves si se utilizan respuestas automatizadas.

Gracias